

Déploiement d'une PKI d'Entreprise et Sécurisation TLS - Nathaniel T

Cette procédure détaille la mise en place d'une Autorité de Certification (CA) interne sous Windows Server (AD CS) et la sécurisation des services web internes. L'objectif est de garantir le chiffrement des flux (HTTPS) et d'éliminer les avertissements de sécurité sur les postes clients membres du domaine.

Étape 1 : Mise en place de l'Autorité de Certification (AD CS)

La première étape consiste à créer l'entité de confiance de votre réseau.

1. Sur le serveur Windows désigné, ouvrez le **Gestionnaire de serveur** et lancez l'assistant **Ajouter des rôles et des fonctionnalités**.
2. Cochez le rôle **Services de certificats Active Directory** (Active Directory Certificate Services).
3. Poursuivez jusqu'à l'installation en ne sélectionnant que le service de rôle **Autorité de certification** (Certification Authority).
4. À la fin de l'installation, cliquez sur le lien de post-configuration (le drapeau jaune).
5. Paramètres critiques lors de la configuration :
 - **Type d'installation** : Entreprise (Enterprise CA). *C'est ce qui permet la distribution automatique du certificat racine via l'Active Directory.*
 - **Type d'autorité** : Autorité Racine (Root CA).
 - **Clé privée** : Créer une nouvelle clé privée (RSA 2048, SHA256).

Prérequis essentiel : Autoriser les SAN (Subject Alternative Name)

Par défaut, une CA Windows rejette les attributs SAN (qui permettent de valider une URL ou une adresse IP) soumis en ligne de commande. Il faut modifier ce comportement de sécurité.

Sur le serveur hébergeant la CA, ouvrez une invite de commandes (Administrateur) et exécutez :

```
certutil -setreg policy\EditFlags +EDITF_ATTRIBUTESUBJECTALTNAME2
net stop certsvc
net start certsvc
```

Étape 2 : Génération de la demande (CSR) côté Serveur Web

Sur le serveur qui va héberger le service web (Linux dans cet exemple), il faut générer une clé privée locale et une Demande de Signature de Certificat (CSR).

Note : Adaptez `serveur.domaine.lan` et l'adresse IP en fonction de votre cible.

Exécutez la commande suivante pour générer la clé (`.key`) et la demande (`.csr`) :

Bash

```
openssl req -newkey rsa:2048 -nodes -keyout serveur.key -out serveur.csr -subj
"/CN=serveur.domaine.lan" -addext "subjectAltName=DNS:serveur.domaine.lan,IP:192.168.X.X"
```

Affichez ensuite le contenu du fichier `.csr` généré (`cat serveur.csr`) et copiez l'intégralité du texte (incluant `-----BEGIN CERTIFICATE REQUEST-----` et `-----END...`).

Étape 3 : Signature du certificat par la CA Windows

1. Sur le serveur Windows (CA), créez un fichier texte nommé `requete.csr` et collez-y le contenu copié à l'étape précédente.
2. Ouvrez une invite de commandes (Administrateur) dans le dossier contenant ce fichier.
3. Soumettez la demande avec le modèle de certificat "Serveur Web" :

DOS

```
certreq -submit -attrib "CertificateTemplate:WebServer" requete.csr serveur.crt
```

1. Une fenêtre s'ouvre : sélectionnez votre Autorité de Certification.
2. Le fichier `serveur.crt` est généré. Il s'agit du certificat officiel, valide et signé.

Étape 4 : Déploiement sur le Serveur Web

Transférez le fichier `serveur.crt` sur votre serveur web cible. La configuration diffère selon le service utilisé.

Cas A : Serveur Nginx ou Apache

Ces serveurs utilisent le certificat public (`.crt`) et la clé privée (`.key`) séparément.

1. Rangez les fichiers de manière sécurisée (ex: `/etc/ssl/certs/` pour le `.crt` et `/etc/ssl/private/` pour le `.key`).
2. Configurez le bloc d'écoute de votre serveur web (exemple Nginx) :

Nginx

```
server {  
    listen 443 ssl;  
    server_name serveur.domaine.lan;  
  
    ssl_certificate /etc/ssl/certs/serveur.crt;  
    ssl_certificate_key /etc/ssl/private/serveur.key;  
    # ... suite de la configuration ...  
}
```

Cas B : Répartiteur de charge HAProxy

HAProxy requiert un format unifié `.pem` regroupant le certificat ET la clé privée.

1. Concaténez les deux fichiers :

Bash

```
cat serveur.crt serveur.key > serveur.pem
```

1. Modifiez le frontend dans `/etc/haproxy/haproxy.cfg` :

Extrait de code

```
frontend http_front  
    bind *:443 ssl crt /chemin/vers/serveur.pem  
    # ... suite de la configuration ...
```

Redémarrez votre service web (`systemctl restart nginx` ou `systemctl restart haproxy`).

Étape 5 : Validation côté Client

Si le poste client est bien membre du domaine Active Directory, il téléchargera automatiquement le certificat de l'Autorité Racine lors de l'actualisation de ses stratégies de groupe.

Pour forcer cette mise à jour sur un poste de test et vérifier la disparation de l'alerte de sécurité dans le navigateur :

1. Ouvrez une invite de commandes sur le PC client.

2. Exécutez : `gpupdate /force`
3. Redémarrez le navigateur web et accédez à l'URL en HTTPS. Le cadenas doit désormais être verrouillé et sécurisé.